



BIAs Táctico

1. Introducción

El Análisis de Impacto al Negocio a nivel Táctico (BIA Táctico) constituye el pilar operativo dentro del Sistema de Gestión de Continuidad del Negocio (SGCN), bajo los lineamientos de la norma internacional **ISO 22301**. A diferencia del análisis estratégico o financiero global, el enfoque táctico se centra en evaluar de manera específica los impactos derivados del cese temporal o total de las actividades y flujos lógicos que componen los procesos críticos de la organización. En el ámbito de las tecnologías de la información y la seguridad digital, las interrupciones no planificadas provocadas por fallas de infraestructura, pérdida de conectividad o incidentes de ciberseguridad disruptivos (como ataques dirigidos de *ransomware* o brechas por *phishing*) exponen a la institución a severas afectaciones operativas, degradación de la calidad del servicio, e incumplimientos regulatorios.

Para la presente implementación del Centro de Detección y Respuesta Ante Ataques Dirigidos (**EDR/MDR**), el BIA Táctico permite determinar con precisión los tiempos críticos de recuperación y los niveles mínimos aceptables de continuidad requeridos para salvaguardar la visibilidad y resiliencia de los 100 nodos de la infraestructura durante cada fase del proyecto.

2. Objetivo

Establecer y valorar los impactos operativos, reputacionales y normativos a través del tiempo ante una interrupción en las actividades específicas de los procesos de: Diagnóstico y Diseño de Arquitectura, Despliegue y Configuración Técnica, y Gestión de Respuesta y Optimización correspondientes al servicio SEC-2026-001.

A través de esta evaluación, se determinan los parámetros críticos de continuidad: el Período Máximo Tolerable de Interrupción (MTPoD), el Objetivo de Tiempo de Recuperación (RTO) y el Objetivo de Continuidad de Negocio Mínimo (MBCO), fundamentando las estrategias de mitigación, los procedimientos manuales de contingencia y las interdependencias técnicas que aseguren la persistencia del monitoreo de seguridad y la protección de los activos críticos.

3. Procedimiento 1

3.1. Identificación del proceso.

Proceso:	Diagnóstico y Diseño de Arquitectura
Grupo de Productos y Servicios:	Implementación de un centro de detección y respuesta ante ataques dirigidos (EDR/MDR).
Responsable (Área/Función):	Ciberseguridad / Consultoría Lógica.
Nombre del responsable:	Velasco Jiménez Luis
Fecha de llenado:	14 de junio de 2026

3.2. Tipo y nivel de impacto al negocio por la interrupción en el proceso.



*Nota: Requisito de ISO 22301:2012: 8.2.2.b) Valorar los **impactos a través del tiempo** por no ejecutar estas actividades. No aplica (N) Bajo (B) Medio (M) Alto (A)*

Tipo de Impacto	0 - 5 Min.	5-15 Min.	15-30 Min.	30-60 Min.	1-2 Horas	2-5 Horas	5-12 Horas	12-24 Horas	1-2 Días	2-5 Días	>5 Días
Pérdida económica	B	B	B	B	B	M	M	M	M	A	A
Incumplimiento legal y/o regulatorio	N	N	N	N	N	N	N	N	B	B	A
Daño a la reputación / Imagen	B	B	B	B	B	M	M	M	A	A	A
Afectación del servicio al cliente	N	N	N	N	N	N	N	N	N	N	N
Pérdida de calidad	B	B	B	B	B	M	M	M	A	A	A
Pérdida de productividad	B	B	B	M	M	M	M	A	A	A	A
Pérdida de control	B	B	B	B	B	M	M	A	A	A	A
Daño a la salud y/o bienestar de personas	N	N	N	N	N	N	N	N	N	N	N
Daño medio-ambiental	N	N	N	N	N	N	N	N	N	N	N

- 3.3. Máximo periodo de interrupción tolerable (MTPoD / MAO) para el proceso. (Tiempo que tomaría para que los impactos adversos, que pueden resultar de no proveer un producto/servicio o la no ejecución de una actividad, sean inaceptables)
 Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Máximo periodo de interrupción tolerable (MTPoD / MAO)										
< 5 Min.	< 15 Min.	< 30 Min.	< 1 Hrs.	< 2 Hrs.	< 5 Hrs.	< 12 Hrs.	< 24 Hrs.	< 48 Hrs.	< 120 Hrs.	Tiempo Especifico
						X				

- 3.4. Identificar tiempo de recuperación objetivo (RTO) para el proceso. (Periodo de tiempo después de un incidente en el que se debe reanudar un producto o servicio, reanudar una actividad o recuperar un recurso) Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Tiempo de recuperación objetivo (RTO)										
< 5 Min.	< 15 Min.	< 30 Min.	< 1 Hrs.	< 2 Hrs.	< 5 Hrs.	< 12 Hrs.	< 24 Hrs.	< 48 Hrs.	< 120 Hrs.	Tiempo Especifico
					X					



3.5. Identificación de objetivo de continuidad del negocio mínimo (MBCO) para el proceso.

(Nivel mínimo de servicio que es aceptable para la organización para lograr sus objetivos de negocio durante una interrupción).

*Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un **nivel mínimo aceptable especificado**, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.*

El objetivo de continuidad mínimo es garantizar que el **Cybersecurity Architect** pueda continuar con la auditoría de activos y el modelado de la red de forma local utilizando plantillas estándar descargadas. Se debe preservar la comunicación vía telefónica con los enlaces técnicos del cliente para el levantamiento de inventarios sin depender de la conectividad permanente a la consola central.

3.6. Identificar actividades que soportan la operación de este proceso.

*Nota: Requisito de ISO 22301:2012: 8.2.2.a) Identificar **actividades** que soportan la provisión de productos y servicios.*

Actividades que soportan el proceso	ID
Solicitud de requerimientos y coordinación de accesos técnicos.	1.1
Ejecución de auditoría de inventario de activos del cliente.	1.2
Análisis de brechas de visibilidad y vectores de ataque críticos.	1.3
Diseño de la arquitectura lógica de integración de la consola Cloud.	1.4
Elaboración y validación de la Matriz de Riesgos y Activos.	1.5

3.7. Identificar opciones actuales de continuidad operacional ej. Procesos manuales, contratistas, trabajo desde casa, etc. (en caso de contar con ellas).

ID	Actividad	Estrategia(s) / mecanismo(s) de continuidad operacional actual
1	Mapeo de activos	Uso de hojas de cálculo locales y formatos de inventario fuera de línea.
2	Diseño técnico	Modelado de diagramas de red en herramientas locales con guardado offline.
3	Comunicación	Uso de redes de telefonía móvil y sesiones presenciales en las oficinas del cliente.

3.8. Interdependencia con otros procesos y/o actividades.

*Nota: Requisito de ISO 22301:2012: 8.2.2.d) Identificar **dependencias** y recursos de soporte para estas actividades, incluyendo proveedores, terceros asociados y otras partes interesadas relevantes.*

Procesos / actividades de los que se **recibe** información.



- 4.3. Máximo periodo de interrupción tolerable (MTPoD / MAO) para el proceso. (Tiempo que tomaría para que los impactos adversos, que pueden resultar de no proveer un producto/servicio o la no ejecución de una actividad, sean inaceptables) Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Máximo periodo de interrupción tolerable (MTPoD / MAO)										
< 5 Min.	< 15 Min.	< 30 Min.	< 1 Hrs.	< 2 Hrs.	< 5 Hrs.	< 12 Hrs.	< 24 Hrs.	< 48 Hrs.	< 120 Hrs.	Tiempo Especifico
				X						

- 4.4. Identificar tiempo de recuperación objetivo (RTO) para el proceso. (Periodo de tiempo después de un incidente en el que se debe reanudar un producto o servicio, reanudar una actividad o recuperar un recurso) Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Tiempo de recuperación objetivo (RTO)										
< 5 Min.	< 15 Min.	< 30 Min.	< 1 Hrs.	< 2 Hrs.	< 5 Hrs.	< 12 Hrs.	< 24 Hrs.	< 48 Hrs.	< 120 Hrs.	Tiempo Especifico
			X							

- 4.5. Identificación de objetivo de continuidad del negocio mínimo (MBCO) para el proceso.
(Nivel mínimo de servicio que es aceptable para la organización para lograr sus objetivos de negocio durante una interrupción).

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

El objetivo de continuidad mínimo es asegurar que los agentes EDR instalados sigan operando de manera autónoma con el motor de análisis heurístico local. En caso de caída de la consola central, el instalador empaquetado debe distribuirse de manera manual mediante unidades de almacenamiento externas, preservando la capacidad de desplegar el software base sin conexión a internet.

- 4.6. Identificar actividades que soportan la operación de este proceso.

Nota: Requisito de ISO 22301:2012: 8.2.2.a) Identificar actividades que soportan la provisión de productos y servicios.



Actividades que soportan el proceso	ID
Configuración base de la consola de gestión Cloud.	1.1
Carga inicial de políticas de detección (firmas y heurística).	1.2
Generación del paquete de instalación optimizado (agente).	1.3
Despliegue progresivo en servidores centrales y terminales.	1.4
Validación de telemetría y diagnóstico de conexiones fallidas (Troubleshooting).	1.5

4.7. Identificar opciones actuales de continuidad operacional ej. Procesos manuales, contratistas, trabajo desde casa, etc. (en caso de contar con ellas).

ID	Actividad	Estrategia(s) / mecanismo(s) de continuidad operacional actual
1	Instalación	Copia local del instalador ejecutable (.msi / .deb) para despliegue directo por USB/Red local.
2	Políticas	Carga de perfiles técnicos de seguridad predefinidos en modo offline.
3	Seguimiento de cobertura	Bitácoras manuales de nodos cubiertos versus inventario físico.

4. 8. Interdependencia con otros procesos y/o actividades.

*Nota: Requisito de ISO 22301:2012: 8.2.2.d) Identificar **dependencias** y recursos de soporte para estas actividades, incluyendo proveedores, terceros asociados y otras partes interesadas relevantes.*

Procesos / actividades de los que se **recibe** información.

ID	Proceso / actividad
1	Proceso de Diagnóstico y Diseño de Arquitectura.

Procesos / actividades a los que se **envía** información.

ID	Proceso / actividad
1	Proceso de Gestión de Respuesta y Optimización.

5. Procedimiento 3

5.1. Identificación del proceso.

Proceso:

Gestión de Respuesta y Optimización

Grupo de Productos y Servicios:

Implementación de un centro de detección y respuesta ante ataques dirigidos (EDR/MDR).



Responsable (Área/Función):

**Operaciones e Inteligencia de Amenazas /
Respuesta a Incidentes.**

Nombre del responsable:

Pérez Hernández Edgar Iván

Fecha de llenado:

14 de junio de 2026

5.2. Tipo y nivel de impacto al negocio por la interrupción en el proceso.

*Nota: Requisito de ISO 22301:2012: 8.2.2.b) Valorar los **impactos a través del tiempo** por no ejecutar estas actividades.*

No aplica (N) Bajo (B) Medio (M) Alto (A)

Tipo de Impacto	0 - 5 Min.	5-15 Min.	15-30 Min.	30-60 Min.	1-2 Horas	2-5 Horas	5-12 Horas	12-24 Horas	1-2 Días	2-5 Días	>5 Días
Pérdida económica	B	B	M	M	A	A	A	A	A	A	A
Incumplimiento legal y/o regulatorio	B	B	B	M	M	A	A	A	A	A	A
Daño a la reputación / Imagen	B	M	M	A	A	A	A	A	A	A	A
Afectación del servicio al cliente	B	B	M	M	A	A	A	A	A	A	A
Pérdida de calidad	B	B	M	M	A	A	A	A	A	A	A
Pérdida de productividad	B	B	B	M	A	A	A	A	A	A	A
Pérdida de control	B	M	A	A	A	A	A	A	A	A	A
Daño a la salud y/o bienestar de personas	N	N	N	N	N	N	N	N	N	N	N
Daño medio-ambiental	N	N	N	N	N	N	N	N	N	N	N

5.3. Máximo periodo de interrupción tolerable (MTPoD / MAO) para el proceso. (Tiempo que tomaría para que los impactos adversos, que pueden resultar de no proveer un producto/servicio o la no ejecución de una actividad, sean inaceptables) Marcar con (X) el tiempo seleccionado.

Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Máximo periodo de interrupción tolerable (MTPoD / MAO)										
< 5 Min.	< 15 Min.	< 30 Min.	< 1 Hrs.	< 2 Hrs.	< 5 Hrs.	< 12 Hrs.	< 24 Hrs.	< 48 Hrs.	< 120 Hrs.	Tiempo Específico
		X								

5.4. Identificar tiempo de recuperación objetivo (RTO) para el proceso. (Periodo de tiempo después de un incidente en el que se debe reanudar un producto o servicio, reanudar una actividad o recuperar un recurso) Marcar con (X) el tiempo seleccionado.



Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un nivel mínimo aceptable especificado, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.

Tiempo de recuperación objetivo (RTO)										
< 5 Min.	< 15 Min.	< 30 Min.	< 1 Hrs.	< 2 Hrs.	< 5 Hrs.	< 12 Hrs.	< 24 Hrs.	< 48 Hrs.	< 120 Hrs.	Tiempo Específico
	X									

5.5. Identificación de objetivo de continuidad del negocio mínimo (MBCO) para el proceso.

(Nivel mínimo de servicio que es aceptable para la organización para lograr sus objetivos de negocio durante una interrupción).

*Nota: Requisito de ISO 22301:2012: 8.2.2.c) Establecer periodos de tiempo y sus prioridades para reanudar estas actividades a un **nivel mínimo aceptable especificado**, tomando en consideración el tiempo en el que los impactos de no reanudar se volverían inaceptables.*

El objetivo de continuidad mínimo es garantizar el aislamiento preventivo y lógico de equipos comprometidos de manera manual por el personal de TI del cliente, utilizando los **Playbooks de Respuesta Inicial impresos**. Se debe mantener un canal alternativo de alertas (teléfono de emergencia o mensajería cifrada móvil) directo con el SOC externo para notificaciones críticas mientras se restablece el tablero principal.

5.6. Identificar actividades que soportan la operación de este proceso.

*Nota: Requisito de ISO 22301:2012: 8.2.2.a) Identificar **actividades** que soportan la provisión de productos y servicios.*

Actividades que soportan el proceso	ID
Monitoreo y triaje analítico de alertas para reducción del 80% de falsos positivos.	1.1
Creación y sintonía fina de Playbooks de aislamiento y contención.	1.2
Ejecución de simulacros de ataque controlado (Red Teaming).	1.3
Capacitación técnica al personal del cliente sobre el uso de dashboards.	1.4
Entrega de tableros de control de KPIs (MTTD/MTTR) y firma de aceptación.	1.5

5.7. Identificar opciones actuales de continuidad operacional ej. Procesos manuales, contratistas, trabajo desde casa, etc. (en caso de contar con ellas).

ID	Actividad	Estrategia(s) / mecanismo(s) de continuidad operacional actual
1	Aislamiento de amenazas	Desconexión física del cable de red del host infectado siguiendo el manual impreso.
2	Capacitación	Uso de manuales impresos y guías rápidas en formato PDF local.
3	Alertamiento	Notificación de incidentes vía llamadas telefónicas directas al enlace de seguridad.



5.8. Interdependencia con otros procesos y/o actividades.

*Nota: Requisito de ISO 22301:2012: 8.2.2.d) Identificar **dependencias** y recursos de soporte para estas actividades, incluyendo proveedores, terceros asociados y otras partes interesadas relevantes.*

Procesos / actividades de los que se **recibe** información.

ID	Proceso / actividad
1	Proceso de Despliegue y Configuración Técnica.

Procesos / actividades a los que se **envía** información.

ID	Proceso / actividad
1	No tiene (Es el fin del proyecto). Entrega directo a la operación del área de TI del cliente y a Revisión por la Dirección .